

Security and Protection of Systems

Lecture 3 *Networking Attacks*

Dr. Zaher Haddad

ITNM3312, Security & Protection of Systems

Outlines

- Networking-Based Attacks
- Server-Based Attacks

Outlines

- Networking-Based Attacks
- Server-Based Attacks

Networking-Based Attacks

There are several attacks that target a network or a process that relies on a network

1. **Interception attacks:** designed to intercept network communications such as: [Man-in-the-middle \(MitM\) attacks](#), and [Reply attacks](#)
2. **Poisoning (inject) attacks:** The act of introducing a substance that harms or destroys network communications such as : [ARP poisoning](#), [DNS poisoning](#), and [Privilege escalation](#)

Interception attacks (1) - MITM

- Interception of legitimate communication and forging a fictitious response to the sender
- Two computers are sending and receiving data with a computer between them
- A MitM could occur between two users
- However, many MitM attacks are between a user and a server

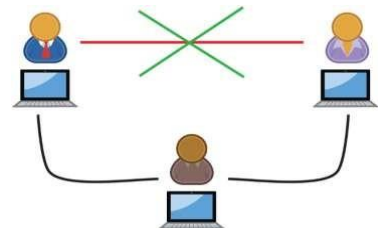
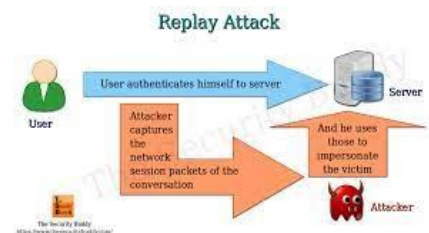


Figure 5-1 Conceptual MITM attack

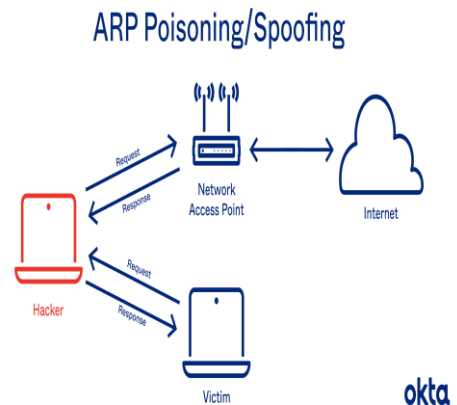
Interception attacks (2) - Replay Attack

- Attacker makes copy of transmission and resend it to the original recipient at a later time such as capturing login credentials
- Methods to prevent replay attacks
 1. Both sides can negotiate and create a random key that is valid for a limited period or for a specific process
 2. Use timestamps in all messages and reject any message that fall outside of a normal window of time



Poisoning attacks (1) - Address Resolution Protocol (ARP)

- Attempts to restore unknown network variable by using one known variable.
- If IP is known but MAC is not, an ARP packet is sent to determine the MAC.
- MAC is stored in an ARP cache for future reference
- ARP poisoning relies upon MAC spoofing, which is imitating another computer by means of changing the MAC

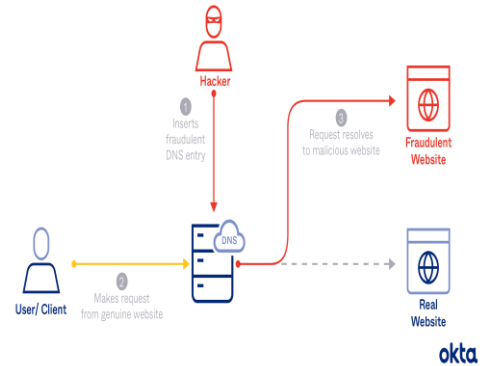


Poisoning attacks (1)- Address Resolution Protocol (ARP)

1. **Steal data** : An attacker can substitute her own MAC address and steal data
2. **Prevent internet access**: An attacker can substitute an invalid MAC address for the network gateway so that no users can access external networks
3. **Man-in-the-middle**: An attacker can be set to receive all communications by substituting that MAC address
4. **Denial of Service attack**: The valid IP address of the target can be substituted with an invalid MAC address, causing all traffic destined for the target to fail

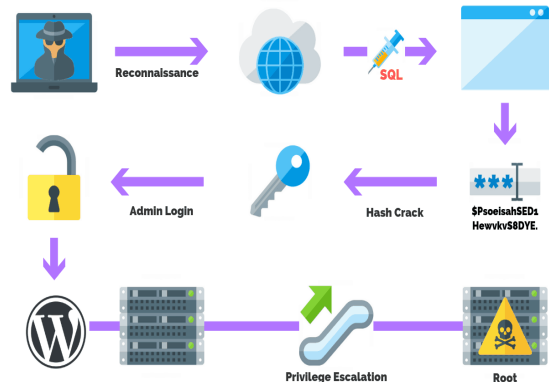
Poisoning attacks (2) - DNS

- Domain Name System is the current basis for name resolution to IP address
- DNS poisoning substitutes DNS addresses to redirect a computer to another device
- Two locations for DNS poisoning
 - Local host table
 - External DNS server



Poisoning attacks (3)- Privilege Escalation

- Access rights is a privileges to access hardware and software resources that are granted to users
- Privilege escalation exploiting a software vulnerability to gain access to resources that the user normally would be restricted from accessing



Poisoning attacks (3)- Privilege Escalation

1- Vertical privilege escalation:

- When a lower privilege user accesses functions restricted to higher privilege users .
- Occurs when an attacker gains access directly to an account with the intent to perform actions.
- This type of attack is easier to pull off since there is no desire to elevate permissions.
- The goal here is to access an account to further spread an attack or access data the user has permissions to.

Poisoning attacks (3)- Privilege Escalation

2- Horizontal privilege escalation:

- When a user with restricted privilege accesses different restricted functions of a similar user.
- Horizontal privilege escalation is a bit tricky to pull off as it requires the attacker to gain access to the account credentials as well as elevating the permissions.
- This type of attack tends to require a deep understanding of the vulnerabilities that affect certain operating systems or the use of hacking tools.

Outlines

- Networking-Based Attacks
- Server-Based Attacks

Server-Based Attacks

- A compromised server can provide threat actors with its privileged contents or provide an opening for attacking any of the devices that access that server
- Typical server attacks include:
 1. Denial of service (DoS)
 2. Web server application attacks
 3. Hijacking
 4. Overflow attacks
 5. Advertising attacks

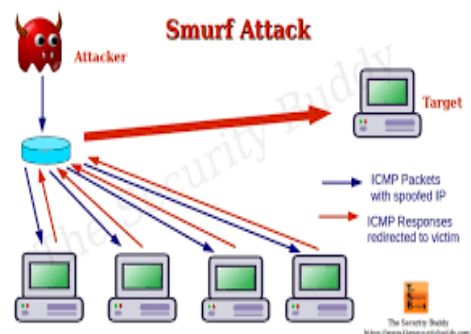
Server-Based Attacks (1)- (DoS)

- Attempts to prevent authorized users from accessing a system by overwhelming it with requests
- Most DoS attacks are **distributed DoS (DDoS)**: Uses multiple devices flooding the server with requests such as :
 1. Smurf attack:
 2. DNS amplification attack:
 3. SYN flood attack:

Server-Based Attacks (1)- (DoS)

1. Smurf attack:

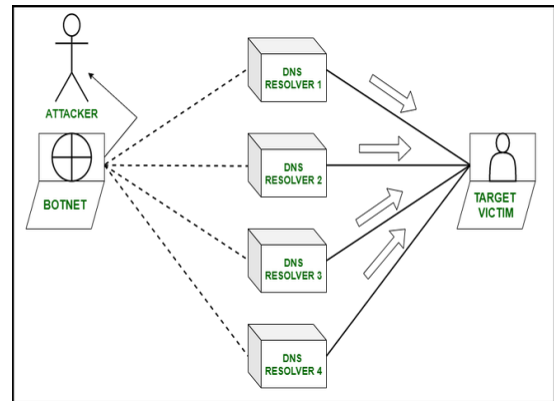
- An attacker broadcasts a network request to all computers on the network but changes the address from which the request came from (called **IP spoofing**),
- All computers send a response to the victim's computer so that it is overwhelmed



Server-Based Attacks (1)- (DoS)

2- DNS amplification attack:

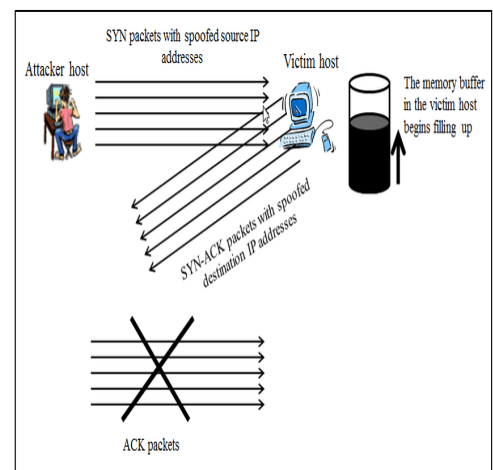
Flood a victim by redirecting valid responses to it using publicly accessible and open DNS servers to flood a system with DNS response traffic



Server-Based Attacks (1)- (DoS)

3- SYN flood attack:

- Takes advantage of procedures for initiating a session
- Attacker sends SYN segments in IP packets to the server
- Attacker modifies the source address of each packet to computer addresses that do not exist or cannot be reached

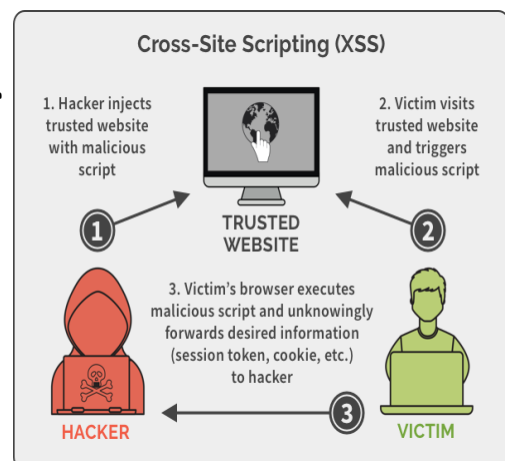


Server-Based Attacks (2)- Web Server Application Attacks

- **Zero-day attack** - an attack that exploits previously unknown vulnerabilities, victims have not time to prepare for or defend against the attack
- Traditional network security devices can block traditional network attacks, but cannot always block web application attacks
- Several different web application attacks target the input from users and are grouped into two categories: **Cross-site attacks** or **Injection attacks**

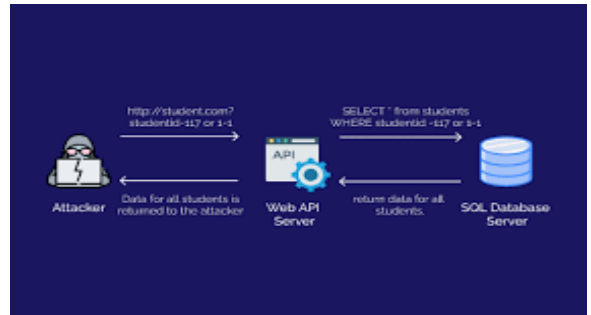
(1) Cross-Site Attacks

- The threat actor takes advantage of web applications that accept user input without validating it before presenting it back to the user
- When victim visits injected Web site: Malicious instructions are sent to victim's browser
- An XSS attack requires a website meets two criteria:
 1. Accepts user input without validating it
 2. Uses input in a response



(2)- Injection Attacks

- Injection attacks introduce new input to exploit a vulnerability
- One of the most common injection attacks, called SQL injection, inserts statements to manipulate a database server
- Forgotten password example:
 - Attacker enters fictitious e-mail address that included a single quotation mark as part of data
 - Response lets attacker know whether input is being validated
 - Attacker enters email field in SQL statement
 - Statement is processed by the database



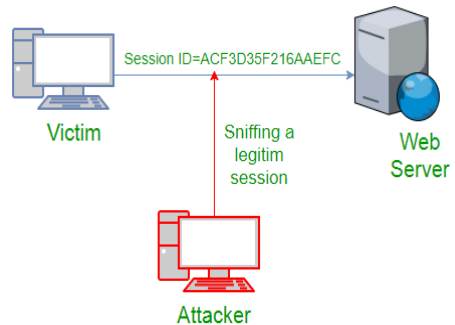
Server-Based Attacks (3)- Hijacking

- Several server attacks are the result of threat actors "commandeering" a technology and then using it for an attack
- Common hijacking attacks include:
 1. Session hijacking
 2. URL hijacking
 3. Domain hijacking
 4. Clickjacking

Server-Based Attacks (3)- Hijacking

1- Session Hijacking Attacker attempts to impersonate user by stealing or guessing session token by

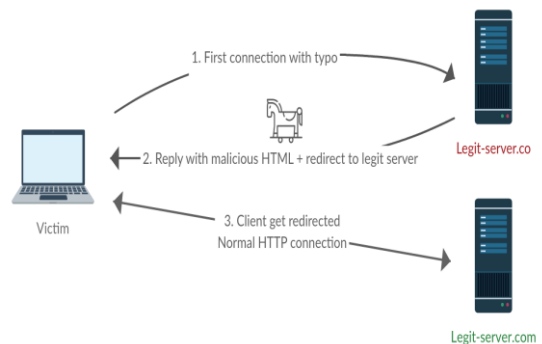
1. By using XSS or other attacks to steal the session token cookie from the victim's computer
2. Eavesdropping on the transmission
3. Guessing the session token
 - (Session token is a random string assigned to an interaction between user and web application)



Server-Based Attacks (3)- Hijacking

2- URL hijacking (also called typo squatting)

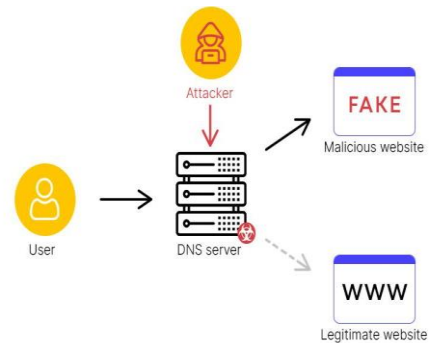
- Users are directed to a fake look-alike site filled with ads for which the attacker receives money for traffic generated to the site
- Attackers purchase the domain names of sites that are spelled similarly to actual sites
- Threat actors are also registering domain names that are one bit different (called **bitsquatting**)



Server-Based Attacks (3)- Hijacking

3- Domain hijacking occurs when a domain pointer that links a domain name to a specific web server is changed by a threat actor

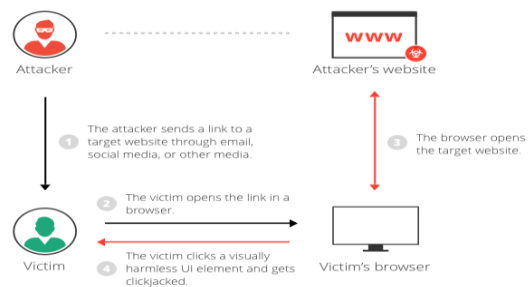
- When a domain is hijacked A threat actor gains access to the domain control panel and redirects the registered domain to a different physical web server



Server-Based Attacks (3)- Hijacking

4- Clickjacking

- Hijacking a mouse click
- The user is tricked into clicking a link that is other than what it appears to be
- Clickjacking often relies upon threat actors who craft a zero-pixel IFrame
- IFrame (short for inline frame) is an HTML element that allows for embedding another HTML document inside the main document
- A zero-pixel IFrame is virtual invisible to the naked eye



Server-Based Attacks (4)- Overflow Attacks

- Consumes memory space with instructions from the attacker

1- Buffer overflow attacks: Occur when a process attempts to store data in RAM beyond the boundaries of a fixed-length storage buffer

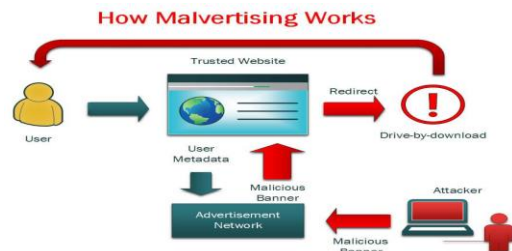
- Attacker can overflow the buffer with a new address pointing to the attacker's malware code

2- Integer overflow is the condition that occurs when the result of an arithmetic operation exceeds the maximum size of the integer type used to store it

- An attacker changes the value of a variable to something outside the range that the programmer had intended by using an integer overflow

Server-Based Attacks (5)- Advertising Attacks

1- Malvertising: Threat actors use third-party advertising networks to distribute malware to unsuspecting users who visit a well-known site.

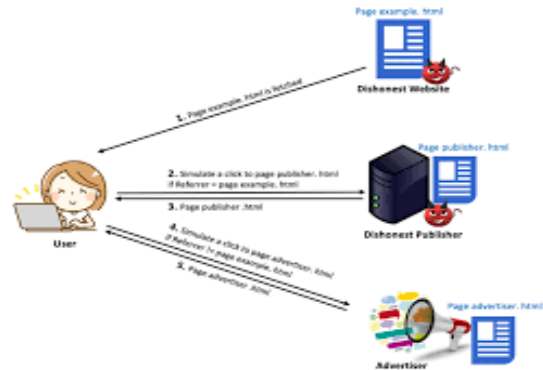


- An ad contains malware redirects visitors who receive it to the attacker's webpage that then downloads Trojans and ransomware onto the user's computer
- Preventing malvertising is difficult
 - Website operators are unaware of the types of ads that are being displayed
 - Users have a false sense of security going to a "mainstream" website
 - Turning off ads that support plugins often disrupts the user's web experience

Server-Based Attacks (5)- Advertising Attacks

2- Ad fraud: Threat actors manipulate pre-roll ads to earn ad revenue that is directed back to them

- Attackers have created a "robo-browser" called Methbot
 - That spoofs all the necessary interactions needed to initiate, carry out, and complete ad auctions



Thanks